

Knowledge Agent

Enterprise RAG System — Evaluated, Cited, Security-Hardened

Atique Ahmed · Generative AI Engineer · github.com/atiquemahar/generative-ai-engineer-roadmap · linkedin.com/in/atique-ahmed-genai

Demo: loom.com/share/f74ed54460e441ccbad20537e366b53a

- Python
- Azure AI Foundry
- Azure AI Search
- FastAPI
- Streamlit
- Docling

THE PROBLEM

Enterprise employees ask questions in their own words. Policy documents use formal terminology. A keyword-based system fails when someone asks *"how much paid vacation do I get?"* when the document says *"Annual Leave Entitlement."*

Beyond retrieval, most RAG systems ask the LLM to generate source citations — and LLMs fabricate. A system that confidently cites a document that was never retrieved is worse than no system at all in compliance-critical workflows. And a system with no security hardening leaks system prompts and internal data under basic injection attacks.

WHAT WAS BUILT

A production-pattern enterprise knowledge agent that answers natural-language questions over 15 internal policy documents (HR, Finance, IT, Vendor Contracts) across 25 days of structured engineering. Served through a FastAPI backend and Streamlit chat UI.

- **Hybrid retrieval** — BM25 + vector search via RRF fusion on Azure AI Search, benchmarked across 4 strategies and 2 evaluation datasets (62 questions total).
- **Structural citation safety** — `_build_sources()` constructs citations from retrieval output only. The LLM never generates source references. Source fabrication is architecturally impossible.
- **Cosine similarity groundedness judge** — replaced a failing LLM-as-judge (silent failures on long multi-document answers) with deterministic semantic similarity scoring. No JSON parsing, no API failures, no empty responses.
- **Automated 5-metric evaluation harness** — 51 questions across 4 categories (direct, multi-document, ambiguous, unanswerable). Run 3 times for consistency.
- **OWASP LLM01 security hardening** — 8 injection attacks tested (direct, indirect, data exfiltration). Baseline passed 4/8. Defensive prompt raised this to 8/8.
- **FastAPI + Streamlit** — `/knowledge/query`, `/chat`, `/extract`, `/health` endpoints. Trace-ID middleware, structured JSON logging, Pydantic v2 validation.

EVALUATION RESULTS — 51 QUESTIONS, 3 RUNS

95%	95%	100%	100%	96%
-----	-----	------	------	-----

Retrieval Hit Rate @5	Answer Groundedness	Citation Accuracy	Refusal Accuracy	Overall Pass Rate
Direct questions (27)		100% retrieval hit rate		
Multi-document questions (10)		100% retrieval hit rate		
Ambiguous questions (6)		67% hit rate — root cause documented		
Unanswerable questions (8)		100% refusal accuracy — zero hallucinations		

SECURITY HARDENING — OWASP LLM01 PROMPT INJECTION (DAY 23)

After completing the RAG pipeline, 8 real-world injection attacks were run against the system covering direct injection, indirect injection via poisoned retrieved documents, and data exfiltration attempts. The baseline (no defensive prompt) failed 4 of 8.

Attack Category	Baseline (no defense)	Defensive Prompt
Direct injection (4 attacks)	2/4 blocked	4/4 blocked ✓
Indirect injection (2 attacks)	2/2 blocked	2/2 blocked ✓
Data exfiltration (2 attacks)	0/2 blocked	2/2 blocked ✓
Overall (8 attacks)	4/8 (50%)	8/8 (100%) ✓

Six defensive rules implemented: identity lock, instruction override resistance, context boundary enforcement (retrieved chunks are data, not commands), system prompt confidentiality, data boundary enforcement, and social engineering resistance (audit/CISO framing does not unlock any rule).

RETRIEVAL STRATEGY BENCHMARK — 31 QUESTIONS × 2 DATASETS

Baseline dataset used document terminology. Hard dataset rewrote the same 31 questions with synonyms and conversational phrasing. Both k=1 and k=5 retrieval depth measured.

Strategy	Baseline Top-1	Hard Top-1	Baseline Top-5	Hard Top-5
Keyword (BM25)	94%	84%	97%	94%
Vector	100%	100%	100%	100%
Hybrid	100%	100%	100%	100%
Hybrid + Semantic ✓ selected	97%	100%	100%	100%

Key finding: Keyword search dropped 10 points on vocabulary mismatch. Hybrid matched Vector on every metric. Semantic reranker introduced a precision regression at k=1 on structured tabular documents — root cause documented.

KEY ENGINEERING DECISIONS

Citations from retrieval, never from LLM

`_build_sources()` constructs citations by reading HybridSearcher output metadata. The LLM generates answer text only. Citation fabrication is structurally impossible — not a prompt constraint, an architectural one. Result: 100% citation accuracy across all 3 evaluation runs.

Cosine similarity over LLM-as-judge

The initial groundedness judge used an LLM to score each answer. It failed silently on long multi-document answers — the model received too much text and returned empty responses. Replaced with semantic cosine similarity: embed answer and each retrieved chunk, compute max similarity, map to 0-3 score. Deterministic, no API failures.

Fixed-500 chunking — cost over complexity

Four chunking strategies tested. Small chunks (200 chars) produced 268 chunks vs 95 for fixed-500 — 3x the embedding cost with identical accuracy. Fixed-500 no-overlap selected: lowest cost, same accuracy, simpler maintenance.

Evaluate first, tune second

The evaluation harness was built before tuning any retrieval parameter. Every change produced a measurable delta. This discipline — not the individual scores — is what separates a production system from a demo.

ARCHITECTURE

```
User Query → Streamlit UI → POST /knowledge/query → FastAPI
```

```
■
```

```
▼
```

```
HybridSearcher (Azure AI Search)
```

```
■ ■ BM25 keyword
```

```
■ ■ Vector (text-embedding-3-small)
```

```
■ ■ Semantic reranking (Microsoft cross-encoder)
```

```
■
```

```
▼
```

```
KnowledgeAgent
```

```
■ ■ _build_context() ← numbered chunk blocks for LLM
```

```
■ ■ AzureOpenAI.responses.create() ← returns {answer, supported, confidence}
```

```
■ ■ _build_sources() ← citations from retrieval only, LLM never touches this
```

```
■
```

```
▼
```

```
{ answer, sources, supported, confidence, retrieval_method, latency_ms }
```